

Errata: A General-Purpose Evaluation Harness for AI Agents, Demonstrated on a Bayesian Vendor-Payment-Fraud Triage Agent

Arif Hussain

Abstract. Standard evaluation reports a single number – “94% accurate” – that hides which mistakes a model makes, how expensive each mistake actually is, whether the model’s stated confidence can be trusted, and whether it can be tricked. This paper presents two connected contributions. First, a small probabilistic agent that decides whether to pay, verify, or escalate a vendor bank-account-change request under genuine uncertainty about the sender’s identity, built with an explicit belief-state table, a hand-derived cost-sensitive decision threshold (refined for a three-action policy that accounts for imperfect verification), and validated through an executed 1,000-case Monte Carlo simulation plus five stress-test scenarios, including a real reliability audit that caught and fixed two genuine implementation bugs. Second, Errata, a domain-agnostic evaluation harness intended to audit any such agent along five dimensions – flat accuracy, hierarchical tree-distance severity, monetary cost, calibration, and adversarial robustness – validated independently through a dry run on a separate demo classifier. We show, concretely, that the fraud-triage agent’s own confusion-matrix scoring collapses three structurally distinct fraud mechanisms into a single class, discarding exactly the information Errata’s tree-distance scoring is designed to recover, and we report this gap, and the not-yet-completed integration between the two systems, honestly as a limitation and a concrete next step.

1 Introduction

Almost every applied machine learning project ends with one number: “my model is X% accurate.” That number is not false, but it is frequently misleading. Consider a company receiving 100 emails a day, of which 8 are genuinely dangerous. A filter that says “safe” to every single email, without reading a word, is 92% accurate – and catches exactly zero of the 8 dangerous cases. This is the well-known *accuracy paradox*: when the class of interest is rare, a trivial policy can score arbitrarily well while providing zero protection against the thing the system was built to catch.

This problem is not hypothetical. The FBI’s Internet Crime Complaint Center (IC3) reported \$3.05 billion in verified Business Email Compromise (BEC) losses in 2025 alone, from 24,768 complaints, and 60% of

all BEC scams specifically impersonate vendors or suppliers [1]. Named cases include Google and Facebook losing a combined \$121 million to a fake-vendor invoice scheme [2], and the City of Baltimore losing \$1.52 million when an attacker inserted new bank details into an active, already-trusted email thread [3].

Our central research question is: *how can an AI agent use probabilistic reasoning to decide what to believe, which evidence is worth its cost, and when it is rational to act – and how can a general-purpose evaluator, independent of the agent’s specific domain, verify that the agent’s own self-reported performance can be trusted?* Narrowed to our concrete problem: *when a supplier requests a bank-account change, which verification step should the agent perform next, and at what belief should it stop verifying and either pay or escalate?*

2 Related Work

Confusion-matrix evaluation for flat categories is a mature, solved problem, implemented correctly by libraries such as `pym` and `scikit-learn`. We do not reinvent this.

Hierarchical, severity-aware scoring is comparatively rare. Apple’s *Neo* system [4] treats a confusion matrix as hierarchical rather than flat, allowing “mistook malware for phishing” to be scored as a smaller error than “mistook phishing for safe.” We initially believed no public implementation of this idea existed; on independent re-verification we found this claim was partially wrong – Neo’s *visualization* code is public on GitHub (`apple/ml-hierarchical-confusion-matrix`) – but it remains a JavaScript/TypeScript rendering library, not a Python function one can import to compute a tree-distance-aware score inside a scoring pipeline. That narrower gap is what Errata’s own `tree.distance()` implementation fills.

Cost-sensitive learning is well established [5], and `scikit-learn` now ships `TunedThresholdClassifierCV`, which selects a decision threshold from a cost matrix rather than defaulting to 0.5 [6]. Our own threshold derivation (Section 5) is independently aligned with this official, current tool. What remains largely absent from the literature is combining cost-sensitivity with hierarchical tree-distance in a single evaluation report.

LLM/agent evaluation harnesses. `AgentSentinel` wraps an agent and checks faithfulness and prompt injection resistance, but its scoring remains pass/fail, with no notion of cost or hierarchical severity. `DeepEval` is a substantially larger, more established framework (over 100 million daily evaluations reported, adoption across more than half of the Fortune 500), offering 50+

research-backed metrics, but these remain individual per-criterion scores rather than a single report combining hierarchy, cost, and calibration.

Adversarial risk. The OWASP Top 10 for LLM Applications [7] keeps Prompt Injection at #1 for a third consecutive year in its 2026 edition (now weighted 75% practitioner survey, 25% analysis of 7,714 documented incidents). The single largest move in the 2026 ranking is *Excessive Agency*, rising from #6 to #3, reflecting that agents are increasingly trusted with real tools and real financial consequences – directly relevant to an agent that can authorize a real payment.

3 Probabilistic View

3.1 Problem Formulation

The agent observes the email requesting a bank-account change – sender address, SPF/DKIM result, message content, and whether the requested account has been used before. It must select *pay*, *verify by phone*, or *hold and escalate*, because whether the request genuinely originated from the real supplier or from an attacker is not directly observable.

3.2 Hidden States and Priors

Five hidden states are considered, including a residual “something else” state, with priors summing to 1.00 (Table 1). All values are stated, hypothetical assumptions, informed by the BEC literature above rather than measured company data.

Hidden state	Prior
Genuine	0.85
Compromised (mailbox hacked)	0.06
Impersonation (lookalike domain)	0.06
Insider / malicious collusion	0.02
Something else (residual)	0.01

Table 1: Hidden states and priors, summing to 1.00.

3.3 Evidence and Likelihoods

Three evidence sources were built, each with a full likelihood table $P(\text{evidence} \mid \text{state})$ for both outcomes: **E1** (is the requested account new?), **E2** (does the sender domain mismatch the known supplier domain?), and **E3** (does the supplier confirm by phone, calling the number already on file, not the number in the email?). A structurally important property: E2’s likelihood for Compromised is exactly 0 – if an attacker has genuinely hijacked the real mailbox, the domain is, by definition, the real domain, so this check cannot detect mailbox compromise at all. This matches documented

industry findings that BEC attacks routinely pass SPF/DKIM/DMARC checks, since those protocols validate sending infrastructure, not human intent.

3.4 A Full Worked Bayesian Update

Observing E1 = “new account,” the update proceeds by multiplying each state’s prior by its likelihood, summing to obtain the normalizing constant $P(\text{new}) = 0.1735$, then dividing:

$$P(\text{state} \mid E) = \frac{P(E \mid \text{state}) P(\text{state})}{\sum_i P(E \mid s_i) P(s_i)} \quad (1)$$

yielding the posterior (Genuine 0.245, Compromised 0.311, Impersonation 0.311, Insider 0.104, Something else 0.029), summing to 1.00. A single piece of evidence moved combined fraud probability from a prior of 15% to a posterior of **75.5%**.

3.5 Entropy: A Counter-Intuitive Finding

Shannon entropy $H = -\sum p_i \log_2 p_i$ measures belief spread. Prior entropy is 0.866 bits; posterior entropy, after the same evidence above, is **2.032 bits** – entropy *increased*. This runs counter to the common assumption that evidence always reduces uncertainty: the evidence invalidated the dominant hypothesis (Genuine) without clearly favoring any single alternative, since Genuine, Compromised, and Impersonation ended up nearly tied. The agent moved from confident to confused-but-alert, which is itself useful information a single accuracy number would never surface.

4 Information-Theoretic View

4.1 Calibration

An agent is calibrated if, across cases where it states X% confidence, roughly X% actually turn out positive – a different property from accuracy. We independently rebuilt the documented model (same priors, likelihoods, and refined thresholds from Section 5) and ran 1,000 simulated cases; the resulting confusion matrix (TP=148, FN=1, FP=124, TN=727) reproduced the primary experiment (Section 6) exactly, confirming a faithful reproduction. Bucketing by final stated fraud probability yields an Expected Calibration Error of **0.0006** and a Brier Score of **0.0165** (0 = perfect; 0.25 = coin-flip). A structurally interesting finding: all 1,000 cases fell into only 2 of 10 possible confidence buckets (0–10% and 90–100%) – the three-zone threshold policy pushes every case toward a decisive extreme rather than lingering in genuine middle-ground uncertainty, a

property of the policy design rather than a flaw in the calibration measurement.

4.2 Jensen–Shannon Divergence

Unlike KL divergence, JSD is symmetric and bounded even when one distribution assigns zero probability to an event the other considers possible. Computed directly on the documented prior/posterior pair above, $JSD(\text{prior}, \text{posterior}) = 0.288$ bits (JS distance 0.536), confirming quantitatively what the entropy finding suggested: a single evidence source produced a substantial belief shift. In production, tracking JSD between a live belief distribution and its original training-time prior is a practical, bounded distribution-shift alarm, avoiding KL divergence’s failure mode of returning infinity the first time a genuinely new case type appears.

4.3 Information Selection

Table 2 compares expected information gain – the prior entropy minus the probability-weighted average posterior entropy across both outcomes of each evidence source – against cost.

Evidence	Info gain	Cost	Notes
E1: New account?	0.347 bits	Rs. 0	Weak on
E2: Domain mismatch?	0.304 bits	Rs. 0	sub-type Blind to
E3: Phone callback	0.347 bits	Rs. 300	Compromised Strongest, not free

Table 2: Expected information gain vs. cost per evidence source.

E1 and E3 are tied as the strongest single checks; E2, despite being structurally blind to mailbox compromise, remains valuable because it is highly diagnostic specifically for Impersonation. The policy implication: run E1 and E2 first, always (free, instant, and complementary); pay for E3 only if belief remains in the uncertain zone after the free checks.

5 Decision Policy

5.1 A Cost-Derived Threshold, and Its Refinement

With $C_{FP} = \text{Rs. } 2,000$ (wrongly holding a genuine request) and $C_{FN} = \text{Rs. } 8,00,000$ (wrongly paying an actual fraud), the standard two-action break-even is $P^* = C_{FP}/(C_{FP} + C_{FN}) = 0.2494\%$ – markedly below an intuitive round number, a direct consequence of the $400\times$ cost asymmetry.

This formula, however, silently assumes exactly two actions. Our agent has three (Pay/Verify/Escalate), and Verify is neither free nor perfect – E3’s own likelihood table states a 5% chance the callback is fooled when the true state is Compromised. We therefore derive a refined three-action threshold accounting for r , the prior-weighted probability that verification itself fails to catch a fraud that is actually present:

$$P_{low} = \frac{C_V}{C_{FN}(1-r)}, \quad r = 5.33\% \quad (2)$$

yielding $P_{low} = 0.0396\%$ – roughly $6.3\times$ lower than the naive two-action figure. Once verification has actually occurred and its cost is sunk, the remaining choice reverts to a plain two-action comparison, for which the original, unrefined $P^* = 0.2494\%$ is correct and is reused as P_{STAR} for that later decision point. $P_{high} = 90\%$ remains a stated policy choice, not yet cost-derived, absent an explicit escalation cost.

5.2 The Umbrella Problem

As a sanity check on the general form of this reasoning: with a 35% chance of rain, carrying an umbrella costing Rs. 20 versus getting wet costing Rs. 200 (a normal walk) yields a 10% break-even; the same umbrella against a Rs. 1,000 wedding outfit yields a 2% break-even. The forecast never changes – only the cost ratio does, exactly mirroring how the $400\times$ fraud-to-delay cost ratio pushes the agent’s own threshold far below any intuitive round number.

6 Experiment

A Monte Carlo simulation (Python, fixed seed=42, isolated `random.Random` instance per batch) draws a true hidden state from the priors, generates E1/E2 from their likelihood tables, runs the Bayesian update above, applies the refined three-action policy, generates E3 only when the uncertain zone is entered, and grades the resulting action against the (only-now-revealed) true state.

A genuine reliability audit. Two real implementation bugs were found and fixed during development, documented rather than silently corrected: (1) an early version reused P_{low} for the post-verification Pay/Escalate decision instead of the correct P_{STAR} , caught via a verbose single-case trace before it could distort batch results; (2) an early version drew all random numbers from Python’s shared global `random` module, making exact reported batch counts silently dependent on unrelated demo code running first – fixed by giving every batch its own isolated RNG, verified by

re-running the identical seed after 500 unrelated global random calls and confirming bit-identical results.

Five stress-test scenarios were executed: (1) base-rate sensitivity (2%/15%/40% fraud), (2) cost-structure sensitivity, (3) verification-effectiveness sensitivity (1%/5%/20% miss rate), (4) threshold-boundary robustness, and (5) adversarial gaming, in which a simulated attacker deliberately forces E1=known and E2=match on every fraud case.

7 Results

At $n = 1,000$ (baseline priors, seed=42): confusion matrix TP=148, FN=1, FP=124, TN=727; Recall = 99.33%; Precision = 54.41%; raw Accuracy = 87.50% (Table 3 shows why this number is misleading); Total Expected Cost = Rs. 13,28,500.

Metric	Value
Recall	99.33%
Precision	54.41%
Accuracy (misleading)	87.50%
Verification rate	93.5%
Total Expected Cost	Rs. 13,28,500

Table 3: Baseline simulation results ($n = 1,000$).

Stress scenarios 1 and 3 independently expose the same underlying gap: P_{STAR} is a *fixed* cost-ratio number that does not adapt to base rate or verification quality. At a 40% fraud base rate, or a 20% verification miss rate, even a genuine case with the best-possible evidence combination computes a final fraud probability (0.80% and 0.336% respectively) that still exceeds the fixed $P_{STAR} = 0.2494\%$, causing near-universal false-positive escalation in those regimes – a genuine, simulation-confirmed limitation of a fixed threshold, hand-verified independently.

Comparison against Errata’s own dry-run validation. On a separate, independently validated demo (22 hand-mocked cases on a safe/suspicious/dangerous tree), Errata’s own scoring reported 77.3% flat accuracy alongside a tree-distance of 0.545, a cost of Rs. 90,91,136 per 100 cases, a calibration error of 0.256, and a 50% adversarial pass rate – demonstrating that the same underlying methodology (flat score, tree distance, cost, calibration, adversarial testing) produces a materially richer report than a single accuracy figure, independent of which concrete domain it is applied to.

8 Failure Analysis

Beyond the two reliability bugs above (classified as *wrong threshold reuse* and *implementation fragility*, both caught and corrected before they could distort reported results), a specific, repeatable pattern emerged in the baseline batch’s 124 false positives: cases where E1/E2/E3 all point toward Genuine still leave several percent of residual belief above the very low P_{low} , so the policy consistently routes them to Verify rather than Pay. This is classified as *wrong threshold* rather than *bad evidence* or *bad prior* – it is a direct, correctly-derived consequence of the $400\times$ cost asymmetry, not a bug, and is reported as the central trade-off finding of the experiment rather than something to be silently tuned away.

A further gap, found by direct comparison against Errata’s design (rather than by re-running any code): the base-model’s own confusion matrix collapses Compromised, Impersonation, and Insider into a single “Fraud” class. Applying Errata’s tree-distance scoring to the same simulation output – available as a saved, per-case `results.csv`, independently reconfirmed to reproduce the baseline confusion matrix exactly – would reveal whether the agent’s false positives and false negatives cluster around specific sub-type confusions, information currently invisible in the flat matrix.

9 Human Discussions

Public discussion (Reddit, X) about this project’s problem framing and prior-art gap is tracked separately in `discussion-record.md`, as a continuing, live activity rather than a fixed set of quotes to be reproduced here; at the time of writing this section is a work-in-progress rather than complete, and is reported as such rather than populated with any invented exchange.

10 Limitations, Ethics, and Human Control

All priors and costs are stated, hypothetical assumptions, not measured from real company data. The phone-callback likelihood table assumes only the email channel, never the phone channel, is compromised; a sufficiently sophisticated attacker who compromises both would defeat this check entirely. $P_{high} = 90\%$ is a policy choice, not yet cost-derived. P_{STAR} is a fixed cost-ratio number, simulation-confirmed not to adapt to base rate or verification quality. Most importantly: **Errata and the fraud-triage agent were developed and independently validated in parallel, but have not yet been integrated into a single pipeline**

– the agent’s own confusion-matrix code, not Errata’s tree-distance/cost/calibration scoring, produced the results in Section 6. This integration, using the already-exported `results.csv`, is reported honestly as immediate future work rather than implied as complete. On ethics: an agent authorizing real financial payments requires human escalation above a stated risk threshold regardless of confidence, which this design implements; no personally identifying information beyond what a real accounts-payable workflow already handles is modeled or stored.

11 New Questions

(1) Would Errata’s tree-distance scoring, applied to the exported `results.csv`, reveal structured sub-type confusion currently invisible to the base-model’s flat confusion matrix? (2) Can P_{high} be derived from an explicit escalation cost the same way P_{low} was refined for verification cost? (3) Does a fixed P_{STAR} generalize acceptably across the base-rate range actually observed in a real deployment, or does the base-model need the same adaptive-threshold treatment P_{low} already received?

12 AI-Use Statement

An AI assistant (Claude, via Microsoft Copilot) was used throughout this project to: explain probability, information-theoretic, and calibration concepts in plain language on request; check arithmetic and re-derive every reported number independently before it was trusted (two genuine numeric errors were found this way and corrected in the decision record rather than silently fixed); debug the simulation script; and assist with LaTeX formatting for this document. The hidden states, priors, costs, evidence likelihood tables, decision thresholds, and the interpretation of every result are the author’s own, arrived at through guided questioning rather than being generated wholesale. All experiments reported were actually run by the author (with the assistant verifying reproducibility), using a fixed, reported random seed.

13 Conclusion

We presented a probabilistic vendor-payment-fraud triage agent, built and validated with real Bayesian reasoning, a cost-derived and subsequently refined decision threshold, and an executed, reliability-audited simulation; and Errata, a general-purpose evaluation harness intended to audit any such agent along five

dimensions beyond flat accuracy. We showed concretely where the two currently diverge – the agent’s own scoring collapses information Errata is designed to preserve – and reported the remaining integration work honestly rather than overstating current completeness.

References

- [1] Internet Crime Complaint Center (IC3), “Business Email Compromise: The \$55 Billion Scam,” FBI Public Service Announcement, 2024/2025 updates.
- [2] Proofpoint, “10 Real-World Business Email Compromise (BEC) Scam Examples,” 2023.
- [3] Veridion, “Vendor Fraud Schemes: 5 Real-Life Examples to Learn From,” 2026.
- [4] J. Görtler, F. Hohman, D. Moritz, K. Wongsuphasawat, D. Ren, R. Nair, M. Kirchner, K. Patel, “Neo: Generalizing Confusion Matrix Visualization to Hierarchical and Multi-Output Labels,” ACM CHI, 2022.
- [5] C. Elkan, “The Foundations of Cost-Sensitive Learning,” IJCAI, 2001.
- [6] scikit-learn developers, “Post-tuning the Decision Threshold for Cost-Sensitive Learning,” `TunedThresholdClassifierCV` documentation, 2025.
- [7] OWASP GenAI Security Project, “OWASP Top 10 for LLM Applications,” 2026 edition.

Appendix A: Required Core Questions

1. **Hidden state:** an unobservable fact – here, the true identity/intent behind a bank-change request. Ours: Genuine, Compromised, Impersonation, Insider, Something else.
2. **Why not predict directly:** a single point prediction discards the agent’s own uncertainty, which is precisely the signal needed to decide when to escalate to a human.
3. **Belief distribution:** a probability over all hidden states; must sum to one because the states are exhaustive and mutually exclusive.
4. **Prior vs. posterior:** prior is belief before evidence (0.85 / 0.06 / 0.06 / 0.02 / 0.01); posterior is belief after (0.245 / 0.311 / 0.311 / 0.104 / 0.029, given E1=new).
5. **Likelihood vs. probability:** likelihood is $P(\text{evidence} \mid \text{state})$, read state-first; it is not the posterior, which is evidence-first.
6. **Agent uncertainty:** the agent holds several explanations simultaneously rather than collapsing to one guess.
7. **Entropy:** $H = -\sum p \log_2 p$; ours rose from 0.866 to 2.032 bits after one evidence source – a genuine, documented exception to “evidence always reduces uncertainty.”
8. **A bit:** one unit of entropy, roughly one good yes/no question’s worth of uncertainty.
9. **Information gain:** $H(\text{prior}) - H(S \mid E)$; E1 and E3 both scored 0.347 bits, E2 scored 0.304.
10. **Conditional entropy:** the probability-weighted average of posterior entropy across all possible evidence outcomes.
11. **Mutual information vs. correlation:** the same quantity as information gain; unlike correlation, it captures non-linear dependence (e.g., a variable and its square have zero correlation but maximal mutual information).
12. **KL divergence:** not a true distance – asymmetric, and infinite if one distribution assigns zero probability to an event the other considers possible.
13. **Asymmetry example:** comparing a fair coin against a model that says “always heads” gives infinite divergence one direction, finite the other.
14. **Jensen–Shannon divergence:** the symmetric, bounded fix, comparing both distributions to their average; computed here as 0.288 bits between our prior and posterior.
15. **Calibration:** whether stated confidence matches observed frequency; ours scored ECE=0.0006, Brier=0.0165 – excellent, though concentrated in only two of ten confidence buckets.
16. **Expected cost / threshold:** the action minimizing expected cost, not the most probable state; ours derived $P^* = 0.2494\%$, later refined to $P_{low} = 0.0396\%$ for the three-action case.
17. **Value of information:** evidence is only worth its cost if some outcome would change the action; if every outcome leads to the same decision, its value is zero regardless of its bit count.
18. **Highly informative but useless:** E2 cannot distinguish Genuine from Compromised at all (both 0.00 likelihood for mismatch), yet still carries real information for Impersonation specifically – demonstrating information value is state-specific, not monolithic.
19. **Distribution shift:** the world changing since priors were set; a rising JSD between a live belief distribution and the original prior is a practical, bounded detection signal.
20. **Stop rule:** act once no remaining check could change the decision, the belief has left the uncertain zone, or the next check’s cost exceeds its expected benefit.